



Incident handler's journal (Feb 25 – Mar 1)

Journal Entries

Date: February 25th	Entry: #1 - Ransomware at U.S clinic
Description	A small U.S healthcare clinic experienced a security incident that rendered their computers unable to access files and data. The attack was orchestrated by malicious attackers caused by targeted phishing emails (the attached file is a malicious malware and will infect the computer/s once downloaded). The company cannot access critical data for their patients and attackers demanded a payment for the ransomware breach to allow access. This resulted in the company to shut down their computer systems and requested the assistance from organizations. The Incident Response Plan, based from NIST framework (SP 800-61), was utilized and discussed below: 1. Preparation: This phase is not excluded (non-existent) since the clinic did not have a proper incident response management team for the security incident. 2. Detection & Analysis: For detection phase, the clinic detected the ransomware incident. For the analysis phase, the clinic contacted the other organizations for technical assistance regarding the incident. 3. Containment, Eradication, and Recovery: For the containment phase, the clinic turned off/shutdown the computers to prevent further spread of malware to other computers/servers but at the cost of unable to access critical patient data (since it is encrypted and demanded payment – Ransomware). Eradication and Recovery phases are non-existent since the clinic does not a dedicated

	IT/Security/Incident Response department to handle the event. 4. Post-Incident Activity: This phase focused on the contact of the organization and nothing more.
Tool(s) used	No cybersecurity tools were used regarding the incident.
The 5 W's	● The individuals that were affected are healthcare employees ● The healthcare clinic got a ransomware breach and demanded a large sum of payment to allow access to critical patient data. ● The security incident occurred on Tuesday and approximately 9:00 AM. ● The location was in United States. ● The reason for the security incident was that the threat actors utilized targeted phishing emails (these contain with files filled with malware) and sent to healthcare employees. Once the employees, even only one, downloaded the content. The attacker gained access and encrypted the files.
Additional notes	The healthcare must have an IT department to handle this incident from ever happening. Either the department is non-existent (since it is a small clinic) or even if there is one, the budget of campaigns, workshops, and programs focused on security awareness, are not prioritized or non-existent.

Date: February 26th	Entry: #2 - Utilizing Wireshark and tcpdump for network packet analysis.
Description	An activity focused on utilizing wireshark and tcpdump. Based from the Incident Response Plan (NIST framework): 1. Detection & Analysis: This phase from the NIST framework is focused on the detection phase (utilized specific protocol for monitoring) and analysis phase (investigate the filtered protocol for unusual packets). 2. As for the other phases, no security breach happened.
Tool(s) used	Wireshark & tcpdump tools.
The 5 W's	● Who created wireshark and tcpdump are Gerald Combs and Van Jacobson, Craig Leres, Steven McCanne respectively ● What are they? Network packet analyzers utilized for network security ● When they are created? Wireshark was created in 1998 and tcpdump in 1988. ● Where they are located? These tools are integrated within Kali Linux OR must be downloaded from the web ● Why are they created? IT and Security teams utilize these open-source tools to filter and analyze specific network protocols.
Additional notes	I encountered these when I tinkered with Kali Linux and THM, HTB labs. I'm currently learning to practice more.

Date: February 27th	Entry: #3 – Investigated and analyzed a suspicious file hash
Description	Investigate a suspicious file hash from an activity. The utilized NIST framework would be: 1. Preparation: For this phase, HR sent an alert ticket focused on a phishing email that contained a malicious file attached. 2. Detection & Analysis: For the detection phase, the cybersecurity analyst utilized VirusTotal to detect malicious content of the URL/file. For the analysis phase, 3. Containment, Eradication, Recovery: For the containment phase, the file was successfully contained due to segmented networks in the server by senior security analysts. For the eradication phase, the file was deleted. For the recovery phase, reset of credentials of the affected system/employee is required as stated from the official playbook dedicated for these scenarios/cases. 4. Post-Incident Activity: For this phase, monitoring of affected system/s and account (HR employee) are required for unusual behavior/patterns. The alert was documented for future reference.
Tool(s) used	VirusTotal, a file and URL investigation web tool to check for malicious content.
The 5 W's	● Who caused this was an unknown malicious actor disguised as an applicant referred to as “Clyde West”. ● What kind of malicious file was indicated here: ○ Known malicious file hash: 54e6ea47eb04634d3e87fd7787e2136ccfbcc80ade34f246a12cf 93bab527f6b ● When it happened was on Wednesday, July 20, 2022, and exactly 09:30:14 AM. ● Where it came was based from an e-mail sent by the malicious hacker to the HR department.

	● The reason as to why and how this happened (which never compromised the overall systems/servers since HR sent this as an alert ticket to the SOC department) is for an attempt at a security breach. Luckily it never happened due to VirusTotal's results.
Additional notes	Imagine with today's technology and AI advances, it would be difficult to address these problems. I hope that tools like VirusTotal would always adapt to counter these situations.

Date: February 28th	Entry: #4 – Understand the importance of SOC playbooks
Description	Help L1 SOC analysts to provide a timely and appropriate response to a phishing incident.
Tool(s) used	SIEM (open-source like Suricata)
The 5 W's	● This playbook is dedicated for SOC Level 1 analysts. ● This is a playbook discussing details appropriate actions when you received a phishing alert and evaluate whether to update the ticket for escalation or close the ticket. ● This event happened on February 28th ● This is an activity online for the Google Cybersecurity's Course 6 ● The reason for a SOC playbook is to guide SOC analysts in a step-by-step plan on monitoring alerts/tickets in a SIEM platform. SOC analysts will evaluate the details of the alert, escalate when it requires the expertise of a senior SOC L2, update the ticket for closure, and documentation.
Additional notes	N/A

INCIDENT FINAL REPORT

Executive summary

The organization experienced a security incident on December 28, 2022, at 7:20 p.m., PT, during which an individual was able to gain unauthorized access to customer personal identifiable information (PII) and financial information. Approximately 50,000 customer records were affected. The financial impact of the incident is estimated to be \$100,000 in direct costs and potential loss of revenue. The incident is now closed and a thorough investigation has been conducted.

Timeline

At approximately 3:13 p.m., PT, on December 22, 2022, an employee received an email from an external email address. The email sender claimed that they had successfully stolen customer data. In exchange for not releasing the data to public forums, the sender requested a \$25,000 cryptocurrency payment. The employee assumed the email was spam and deleted it.

On December 28, 2022, the same employee received another email from the same sender. This email included a sample of the stolen customer data and an increased payment demand of \$50,000.

On the same day, the employee notified the security team, who began their investigation into the incident. Between December 28 and December 31, 2022, the security team concentrated on determining how the data was stolen and the extent of the theft.

Investigation

The security team received the alert and traveled on-site to begin the investigation.

The root cause of the incident was identified as a vulnerability in the e-commerce web application. This vulnerability allowed the attacker to perform a forced browsing attack and access customer transaction data by modifying the order number included in the URL string of a purchase confirmation page. This vulnerability allowed the attacker to access customer purchase confirmation pages, exposing customer data, which the attacker then collected and exfiltrated.

After confirming the web application vulnerability, the security team analyzed the web application access logs. The logs indicated that the attacker accessed the information of thousands of purchase confirmation pages.

Response and remediation

The organization collaborated with the public relations department to disclose the data breach to its customers. Additionally, the organization offered free identity protection services to customers affected by the incident.

After the security team reviewed the associated web server logs, the cause of the attack was very clear. There was a single log source showing an exceptionally high volume of sequentially listed customer orders.

Recommendations

To prevent future recurrences, we are taking the following actions:

- Perform routine vulnerability scans and penetration testing.
- Implement the following access control mechanisms:
 - Implement allowlisting to allow access to a specified set of URLs and automatically block all requests outside of this URL range.
 - Ensure that only authenticated users are authorized access to content.

Date: February 28th	Entry: #5 – Incident Response Finale
Description	The organization experienced a security incident on December 28, 2022, at 7:20 p.m., PT, during which an individual was able to gain unauthorized access to customer personal identifiable information (PII) and financial information. Approximately 50,000 customer records were affected. The financial impact of the incident is estimated to be \$100,000 in direct costs and potential loss of revenue. The incident is now closed and a thorough investigation has been conducted. As for the NIST framework for Incident Response: 1. Preparation: This phase focused on the security team preparing for the investigation of a security incident as stated from the received alert. 2. Detection & Analysis: For detection phase, the security team investigated the incident and discovered a vulnerability. For the analysis phase, it was revealed that it was vulnerability from the web application that can be modified to access sensitive customer records. 3. Containment, Eradication, Recovery: For the containment phase and eradication phase, there was nothing to salvage since the damage was done. The organization collaborated with the PR department for the incident disclosure. The recovery phase focused on the organization offer free identity protection services (username/password resets, etc.) to affected customers. 4. Post-Incident Activity: The incident left the organization costing \$100,000 worth of damages for the overall financial impact and loss of revenue from customers, partners, and more. Recommendations were focused on routine scans, stricter access control for employees, allowlist implementation, and user authentication for authorized access.
Tool(s) used	VAPT tools (wireshark, nmap, etc.), access control, network router/firewall

	were listed as recommendations.
The 5 W's	● Who were affected? 50,000 customers with sensitive records (Personal Identifiable Information [PII], financial records, etc.) from a business organization. ● What happened was a security incident where an e-commerce web application had a vulnerability that let the attacker perform forced browsing attack and access transaction data from customers. The data was collected and exfiltrated. ● When did it happen? It was December 22, 2022 and approximately 3:13PM when the security incident happened. ● Where was the incident located? The discussed information was not disclosed. ● Why and how did it happen? Security team investigated the incident and discovered a vulnerability from the e-commerce web application that can modify the order number included in the URL string of a purchase confirmation page. The attacker forced the attack and collected & exfiltrated data from 50,000 customer records based from purchase confirmation pages. The security team also reviewed the web server logs and discovered one single log source that showed an exceptionally high volume of listed customer orders.
Additional notes	Security incidents are low, not zero. Therefore, continuous monitoring, routine checkups, updates and patches of the web application as well as reconfiguration of settings from the servers, firewalls, and network routers are needed to ensure protection.

Reflection/Notes:

1. I learned a lot on what are the key details and specifics needed. From using the tools needed to reading documentation, it was a great experience and essential for my growth.
2. I still have a long way to go; this is a good start and will continue on improving and gaining skills needed to become a cybersecurity analyst/developer.